

Structured LLM-Assisted YARA Rule Generation

Static-only malware-family detection on MOTIF

Yassir BOUSSETA

Introduction to Malware Analysis

March 2026

Outline

- 1 Overview
- 2 Method
- 3 Results
- 4 Packaging
- 5 Appendix

Problem & Scope

Project goal

Generate YARA rules automatically from malware-family samples using a real LLM backend, without malware execution.

Scope

- Static analysis only
- PE-oriented features
- Same-split comparison against deterministic baselines

What matters

- Mean F_1
- Target recall
- Benign false-positive rate
- Family coverage

Dataset & Split Discipline

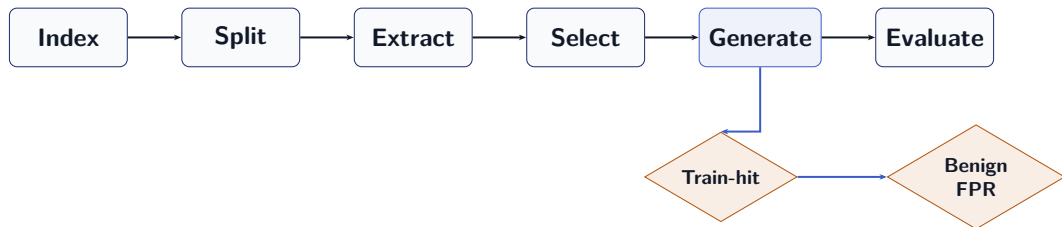
MOTIF

138 eligible malware families, PE samples only, minimum 6 samples per family.

Split	Purpose	Used in
train_target	family-positive examples	prompting / train-hit gate
test_target	held-out family evaluation	final metrics only
benign_dev	negative examples / FPR gate	selection / gating
benign_test	held-out benign evaluation	final metrics only

Parameters: test_ratio=0.3, benign_dev_ratio=0.6, seed=42

Pipeline



Extract / Select

- strings, imports, PE metadata
- TF-IDF + chi-squared ranking
- target vs other + benign_dev

Generate / Accept

- primary path: structured JSON
- deterministic renderer
- repair loop: max 3
- train hits + benign FPR ≤ 0.02

Executed Comparison Set

Method	Status	Role
llmyara-llm	primary	structured LLM generation with acceptance gates
topstrings	reproduced	deterministic string baseline
apiary-static	re-implemented	static import-discriminative baseline
autoyara-biclust	re-implemented	byte n-gram biclustering baseline

Main Results

Method	OK	Mean F_1	Mean TPR	Benign FPR	Specificity
llmyara-llm	128/138	0.4240	0.4043	0.0000	0.9988
topstrings	138/138	0.4195	0.4797	0.0061	0.9924
apiary-static	138/138	0.1557	0.6999	0.0718	0.8638
autoyara-biccluster	138/138	0.2760	0.7965	0.1183	0.8180

Read this table carefully

- all-family metrics; rejected families contribute zero
- llmyara-llm: numerically highest mean F_1 , but only 128/138 accepted families
- topstrings: full 138/138 coverage

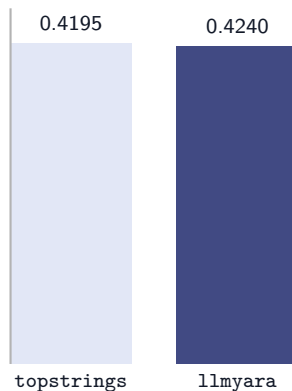
F1 vs. topstrings

Paired randomization

- $\Delta F_1 = +0.004442$
- $p = 0.84843$
- $n = 138$ families

Interpretation

- not statistically significant
- similar to topstrings on mean F_1
- stronger than apiary-static and autoyara-biclust



$p = 0.848$; not significant

Recall vs. False Positives

Method	TPR	Benign FPR	Spec.	Profile
llmyara-llm	0.4043	0.0000	0.9988	low recall, zero benign FP
topstrings	0.4797	0.0061	0.9924	moderate recall, low benign FP
apiary-static	0.6999	0.0718	0.8638	high recall, much higher benign FP
autoyara-biclust	0.7965	0.1183	0.8180	highest recall, worst benign FP

Main trade-off

llmyara-llm sacrifices recall and coverage to keep benign FPR at zero.

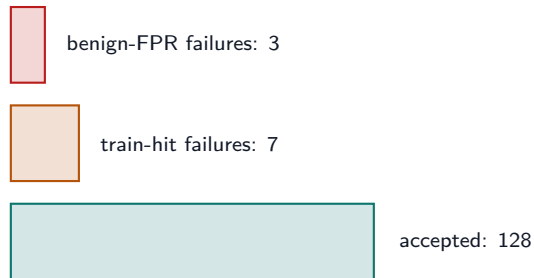
Coverage Gap & Failure Analysis

Accepted vs rejected

- accepted: 128 families
- rejected: 10 families
- all rejected families exhausted 3 repairs

Reason counts

- `train_target_hits_below_min`: 7
- `benign_dev_fpr_exceeded`: 3



Example Accepted Rule

```
strings:  
  $a1 = "inet_addr" ascii  
condition:  
  uint16(0) == 0x5A4D and  
  pe.imports("advapi32.dll",  
             "abortsystemshutdowna") and  
  1 of them
```

Nanolocker

- $F_1 = 1.0$
- TPR = 1.0
- benign FPR = 0.0
- selected strings become YARA terms
- import predicate adds structure
- condition remains short and auditable

Implementation & Reproducibility

Implementation quality

- complete CLI workflow
- Dockerfile + docker-compose
- `start.sh` entrypoint
- documented README and architecture notes

Saved evidence

- audit bundle under `artifacts/final_motif_audit/`
- comparison summaries
- significance outputs
- failure analysis
- committed example rule

Limitations & Takeaway

Limitations

- static-only features
- tied with topstrings on F_1
- lower recall than byte-oriented baselines
- 10/138 families rejected
- single dataset and single model

Takeaway

- benign FPR = 0.0000
- specificity = 0.9988
- 128 / 138 accepted families
- numerically highest mean F_1 among executed methods

The method favors lower false positives over recall and full coverage.

Appendix: Full Metric Table

Method	OK	F_1	TPR	FPR	Spec.	Comp.	Rules
llmyara-llm	128/138	0.4240	0.4043	0.0000	0.9988	11.78	128
topstrings	138/138	0.4195	0.4797	0.0061	0.9924	8.94	138
apiary-static	138/138	0.1557	0.6999	0.0718	0.8638	8.51	138
autoyara-biclust	138/138	0.2760	0.7965	0.1183	0.8180	11.49	138

Appendix: Rule Complexity

Method	Mean complexity	Mean strings	Mean clauses
llmyara-llm	11.78	9.57	2.21
topstrings	8.94	7.94	1.00
apiary-static	8.51	7.51	1.00
autoyara-biclust	11.49	5.85	5.64

Appendix: Rejected Family Details

Family	Reason	Repairs	Train hits
carbanak	train-hit below min	3	0
dridex	train-hit below min	3	0
mosaicregressor	train-hit below min	3	0
nazar	train-hit below min	3	0
nymaim	train-hit below min	3	0
phorpiex	train-hit below min	3	0
smokeloader	train-hit below min	3	0
cerber	benign-dev FPR exceeded	3	2
dharma	benign-dev FPR exceeded	3	6
ryuk	benign-dev FPR exceeded	3	15

Appendix: Full Nanolocker Rule Excerpt

```
import "pe"
rule nanolocker_candidate_01 {
  strings:
    $a1 = "0a-%m]mm" ascii
    $a7 = "inet_addr" ascii
    $a10 = "\\mhavgco&" ascii
  condition:
    uint16(0) == 0x5A4D and
    pe.imports("advapi32.dll", "abortsystemshutdowna") and
    1 of them
}
```